Recuperación de contraseñas accesible y segura

Matías Lira Breyan Sebastián

—

Desarrollo Web Profesional

—

José Miguel Carrera Pacheco

¿QUÉ ES UN TOKEN DE RECUPERACIÓN?

Un token de recuperación es un código o identificador único que se genera cuando un usuario solicita recuperar el acceso a su cuenta, generalmente cuando olvida su contraseña.

Este token sirve para verificar que la persona que solicita el cambio tiene permiso para hacerlo.

Cómo funciona

1. El usuario solicita recuperar su contraseña.
2. El sistema genera un token único y temporal.
3. El token se envía al usuario (por ejemplo, por correo electrónico).
4. El usuario utiliza ese token para acceder a una página donde puede cambiar su contraseña.

Ejemplo

Un enlace típico puede verse así:

`https://sitio.com/recuperar?token=abc123xyz`

Ese token identifica de forma segura la solicitud de recuperación.

¿POR QUÉ DEBEN EXPIRAR LOS TOKENS?

Los tokens de recuperación deben tener un tiempo de vida limitado por razones de seguridad.

Razones principales

Evitar accesos no autorizados

Si un token no expira, cualquier persona que lo obtenga podría usarlo en cualquier momento.

Reducir riesgos de filtración

Los enlaces pueden quedar guardados en:

- correos electrónicos
- historial del navegador
- registros del sistema

Si no expiran, se vuelven vulnerables.

Limitar el tiempo de ataque

Un token con duración corta (por ejemplo, 15–60 minutos) reduce la ventana de oportunidad para un atacante.

¿QUÉ ATAQUES EXISTEN EN FLUJOS DE RECUPERACIÓN?

Los sistemas de recuperación de contraseña pueden ser un punto vulnerable si no están bien diseñados.

Organizaciones como OWASP Foundation analizan estos riesgos.

Enumeración de usuarios

Ocurre cuando el sistema revela si un correo electrónico está registrado.

Ejemplo incorrecto:

Este correo no está registrado.

Esto permite a un atacante identificar cuentas válidas.

Robo de tokens

Si un atacante obtiene el token (por ejemplo, mediante phishing o acceso al correo), puede cambiar la contraseña.

Tokens predecibles

Si los tokens no son aleatorios o son fáciles de adivinar, pueden ser explotados.

Reutilización de tokens

Si un token puede usarse más de una vez, un atacante podría reutilizarlo.

Ataques de fuerza bruta

Intentar múltiples combinaciones de tokens hasta encontrar uno válido.

¿CÓMO SE DISEÑA UN FLUJO ACCESIBLE PARA RECUPERACIÓN DE ACCESO?

Un flujo de recuperación debe ser seguro, claro y accesible para todos los usuarios, incluyendo personas con discapacidades.

Las recomendaciones de accesibilidad provienen del World Wide Web Consortium.

Características de un buen flujo accesible

1. Instrucciones claras

El sistema debe explicar claramente qué hacer en cada paso.

Ejemplo:

Ingresa tu correo para recibir un enlace de recuperación.

2. Mensajes neutrales

Evitar revelar información sensible.

Ejemplo:

Si el correo está registrado, recibirás un enlace de recuperación.

3. Formularios accesibles

- etiquetas claras (label)
- navegación con teclado
- mensajes de error comprensibles

4. Uso de correo electrónico claro

El mensaje enviado debe incluir:

- instrucciones simples
- enlace visible
- advertencia de expiración

5. Confirmación de acciones

Después de cambiar la contraseña, el sistema debe mostrar un mensaje claro:

Tu contraseña ha sido actualizada correctamente.

6. Compatibilidad con lectores de pantalla

Se pueden usar atributos como:

- aria-live para mensajes dinámicos
- etiquetas descriptivas

Buenas prácticas adicionales

- permitir reenviar el enlace
- limitar intentos de recuperación
- ofrecer soporte adicional si el usuario no puede acceder a su correo